

CommitScope User Guide

2.4.0 / Prepare a trusted installation

Use a reviewed CommitScope checkout separate from the application. Supported hosts: macOS or glibc Linux, x86_64/ARM64, Python 3.11-3.14. Native Windows is outside scope; use supported Linux under WSL2. Prerequisites include Git, venv/pip, certificate roots, and approved outbound HTTPS.

No public v2.4.0 tag or release is claimed by this checkout. Install the exact reviewed source. Scanner bootstrap downloads pinned tools and databases; it does not install target dependencies or execute the target.

```
pipx install /absolute/path/to/commitscope
commitscope preflight
commitscope bootstrap
commitscope doctor
```

Sign in using the intended account

Install official Claude Code 2.1.259 or newer and sign in as the same unprivileged OS user who will run reviews. The wrapper pins 2.1.278 for new installs but does not upgrade existing CLIs. Update an older CLI through the official channel and check `claude --version` before review. Corporate authentication is account-only. Resolve ambient API keys, provider routing, model overrides, and profile overrides; the command rejects them and has no API/provider fallback.

```
sh scripts/install-claude.sh
claude auth login
claude auth status
```

Choose commit, policy, and storage

Commit or stash all target changes, including untracked files. Use the full lowercase 40- or 64-character commit ID. Review `examples/review-policy.json` and place the approved policy outside the target. Remove recognizable credential forms, including Bearer/Basic authorization values and URLs with user information; screening cannot identify every unknown secret.

Choose a new output directory outside the target. Its existing parent must belong to the current user or root and must not be group/world writable. Symlinked paths and existing output directories are refused.

```
git -C /absolute/path/to/application status --short
git -C /absolute/path/to/application rev-parse HEAD
```

Run one corporate review

All five stages are required

Semgrep, Gitleaks, and Trivy must complete. Hunter and Verifier are mandatory for corporate completion. The command uses an immutable snapshot and writes the manifest last. Use the organization's approved exact model ID; aliases such as sonnet are rejected.

The following values illustrate the command shape. Replace the paths, commit ID, and APPROVED_EXACT_MODEL_ID with reviewed values. --allow-code-upload explicitly consents to sending the bounded screened source packet to Anthropic. Screening is not complete secret sanitization.

```
commitscope review \  
--repo /absolute/path/to/application \  
--ref 0123456789abcdef0123456789abcdef01234567 \  
--policy /protected/review-policy.json \  
--out /protected/reviews/run-id \  
--auth account \  
--allow-code-upload \  
--model APPROVED_EXACT_MODEL_ID
```

Strict dependencies and explicit exceptions

Dependency inventory is strict by default. Only for an audited standard-library-only target, add --allow-empty-sca with the owner's reason after reviewing imports and build metadata. The reason is recorded evidence, not independently authenticated proof or permission to ignore a missing lockfile.

Account login failure, exhausted quota, unavailable model, network or timeout failure, malformed output, and missing scanner or AI coverage produce INCOMPLETE. Preserve the failed run, resolve the cause, and start a new run.

Read the state and exit code

READY_FOR_HUMAN_REVIEW / 0: required stages completed; no normalized finding met the policy threshold. Preserve and hand off the run for a human decision.

FINDINGS_REQUIRE_TRIAGE / 1: required stages completed and findings met the threshold. Preserve and hand off for triage.

INCOMPLETE / 2: a prerequisite, stage, or required verification failed. Corporate review has not completed.

READY_FOR_HUMAN_REVIEW does not approve a merge or assert that the application is secure.

Hand off and recheck

Protect and verify the original run

Give the unchanged confidential run directory to the assigned human reviewer through protected storage. Share normalized top-level reports and evidence/ only under company rules. Source packets, raw scanner output, model envelopes, and diagnostics under private/ must not be published or committed.

```
commitscope verify-review --run /protected/reviews/run-id
```

Understand what verification proves

verify-review checks exact artifact layout, safe types and permissions, hashes, commit/snapshot identity, policy/resource hashes, completed scanners and Hunter/Verifier coverage, and decision consistency. Valid evidence returns its recorded 0 or 1 class; changed, missing, inconsistent, or incomplete evidence returns INCOMPLETE / 2.

The manifest is unsigned: authorship and immutability are not cryptographically verified. Inspect the evidence and complete a copy of reviewer-decision-template.json in the protected decision system with the verified manifest hash. Human identity and approval remain external controls.

Rerun for every new commit

After a fix, use a new commit and a new output directory. Repeat scanners, Hunter, Verifier, manifest verification, and human triage. Keep earlier evidence unchanged. A missing finding in compare is not proof of remediation.

Partial diagnostics are not corporate acceptance

The supplied GitHub Action and CI workflows run scanners only. They do not perform the required local Hunter/Verifier workflow. Never upload private/ or give CI a developer's Claude login.

SCANNERS_VERIFIED_AI_NOT_RUN is not completed corporate acceptance. It describes scanner-only acceptance evidence. Compatibility commands commitscope scan and commitscope ai, including a manually assembled sequence, do not replace commitscope review.

Unit tests and generated documents do not establish live readiness. Operators must separately validate supported hosts, real scanner execution, and explicitly authorized Hunter/Verifier runs on controlled fixtures. References: START-HERE.md and docs/VERIFICATION.md. Source mode: python3 -I review.py <command> from the trusted checkout.